

Halden Distribution Ltd. — Network access policy

Purpose: state, in one place, who may reach what on Halden's network, how remote access is granted, and what guests may do. It exists so that an access decision is a policy decision with a name against it, rather than whoever was last asked. **Owner:** IT · **Approvers:** Managing Director (policy), department heads (their departments) **Version:** 1.0 (draft for approval) · **Date:** 2026-10-02 · **Review:** quarterly

1. Principles

1. **Deny by default.** Traffic between zones is blocked unless this policy or the rule matrix explicitly allows it.

1. **Least privilege at the network level.** A zone reaches the services its work needs, not "the servers".

1. **Business owns access.** IT implements access; the department that needs it justifies it and owns the exception.

- 1. **Every exception is written down** with a number, an owner, a justification and a review date.
- 2. **Remote access is a privilege**, granted per person, reviewed quarterly, and removed on the day someone leaves their role.

2. Zones and who may reach them

Zone	Who may reach it	Notes
Servers (192.168.10.0/24)	Staff (AD and file services only), Warehouse (same), Admin (all)	Not reachable from Guest, and not reachable from IoT except one file share
Warehouse (192.168.20.0/24)	Warehouse users, Admin	Joined to HQ by an encrypted tunnel
Staff (192.168.30.0/24)	Staff users, Admin	Corporate Wi-Fi devices also land here
Management (192.168.40.0/24)	Admin only	Nothing else reaches this zone, including Remote staff. It holds the admin workstation, the hypervisor and the backup repository
Guest (192.168.50.0/24)	Guests (internet only)	Client isolation on: guests cannot see each other
Devices / IoT (192.168.60.0/24)	Devices (one file share for scanning, and name resolution)	No internet, by design
Remote staff (VPN, 192.168.70.0/24)	Approved remote users	Same as being in the office, except management systems

The authoritative technical detail — source zone, destination, service, action, owner, justification — is the **rule matrix** (`../configs/p06-zone-rule-matrix.csv` and `.md`). This policy is the business-readable view of the same decisions.

3. Remote access (VPN)

Item	Rule
Who may request	Staff whose role requires off-site access to company systems (home working, on call, travel)
Approval	Line manager, with a business reason; IT cannot approve its own request without a manager
Technical controls	A certificate issued to the user's device, membership of <code>G_VPN_Users</code> , and a second factor (an approval on the user's phone)
What is granted	The same access as being in the office, excluding management systems
IT administrative access over VPN	Separate group (<code>G_VPN_IT</code>), separate justification, and it is logged
Review	Quarterly, against the list of people who actually connected
Removal	On the employee's last day, and immediately on request from the manager
Device requirements	A company-managed device with an up-to-date operating system; no personal devices by default
Prohibited	Sharing a profile or certificate with anyone, including colleagues, family or contractors

4. Guest Wi-Fi (visitors, contractors, interviewees)

Item	Rule
Access	Internet only, via a voucher issued at reception
Isolation	Guests cannot reach company systems, and cannot reach other guest devices
Acceptable use	Displayed before vouchers are issued (see <code>p06-guest-wifi-notice.md</code>): no illegal activity, no attempt to access company systems, no streaming that saturates the link
Records	Voucher issue time and duration are recorded; the visitor does not need to give personal data
Withdrawal	IT may disable guest access at any time; a breach of the notice ends the visit's access

5. Exceptions

Any request for a flow that this policy does not allow:

1. **Raise it as a ticket** with the source system, the destination system, the service, and the business reason.
1. **Name an owner** in the business, not in IT.
2. **IT assesses it** — the narrowest rule that satisfies the need, time-boxed where possible.
3. **The manager approves it**; read-only and single-host rules are preferred over whole subnets.
4. **It is recorded** as a numbered rule in the matrix, and enters the quarterly review.
5. **It expires or is renewed** at review. An exception that nobody reviews is removed.

Examples of what will **not** be granted: "open the whole management zone for a while", "all staff can reach all servers", permanent internet access for a device that needs one update.

6. Responsibilities

Role	Responsibility
Managing Director	Approves this policy and any exception that widens access to management systems
Department heads	Justify and own their departments' access; decide their own team's remote access requests
IT	Implements and documents access, keeps the rule matrix and diagrams current, reviews exceptions quarterly, alerts on unapproved changes
All staff	Use only the access granted; report a lost laptop or a suspected compromise immediately

7. Monitoring

- Denied traffic on the firewall is logged and reviewed (unexpected denies usually mean a missing documented rule; unexpected *allows* mean a rule nobody remembers adding).
- Firewall configuration backups are taken before and after every change and compared; a change with no approved change record is raised as an incident.
- Remote access events (granted and denied) are logged and read during the quarterly review.

8. Approval

Role	Name	Date	Signature / approval
Managing Director (policy)			
Finance Director			
HR Director			
Sales Director			
Operations Director (warehouse and IoT devices)			
IT (implementation)			

Status: draft v1.0 for approval. **The approval column is deliberately unsigned** until the review actually happens; it is not pre-filled. Halden Distribution Ltd. is a fictional company, so these approvals represent the lab owner's decision, not a real customer sign-off.